

Week 3 Internship - Vulnerability Assessment Report

Target: OWASP Juice Shop (127.0.0.1:3000) running in Docker on Kali Linux.

Executive Summary

A vulnerability assessment was performed in an isolated lab using Nmap, Nikto, Burp Suite and Wireshark.

Scope

Assessment limited to the local OWASP Juice Shop instance.

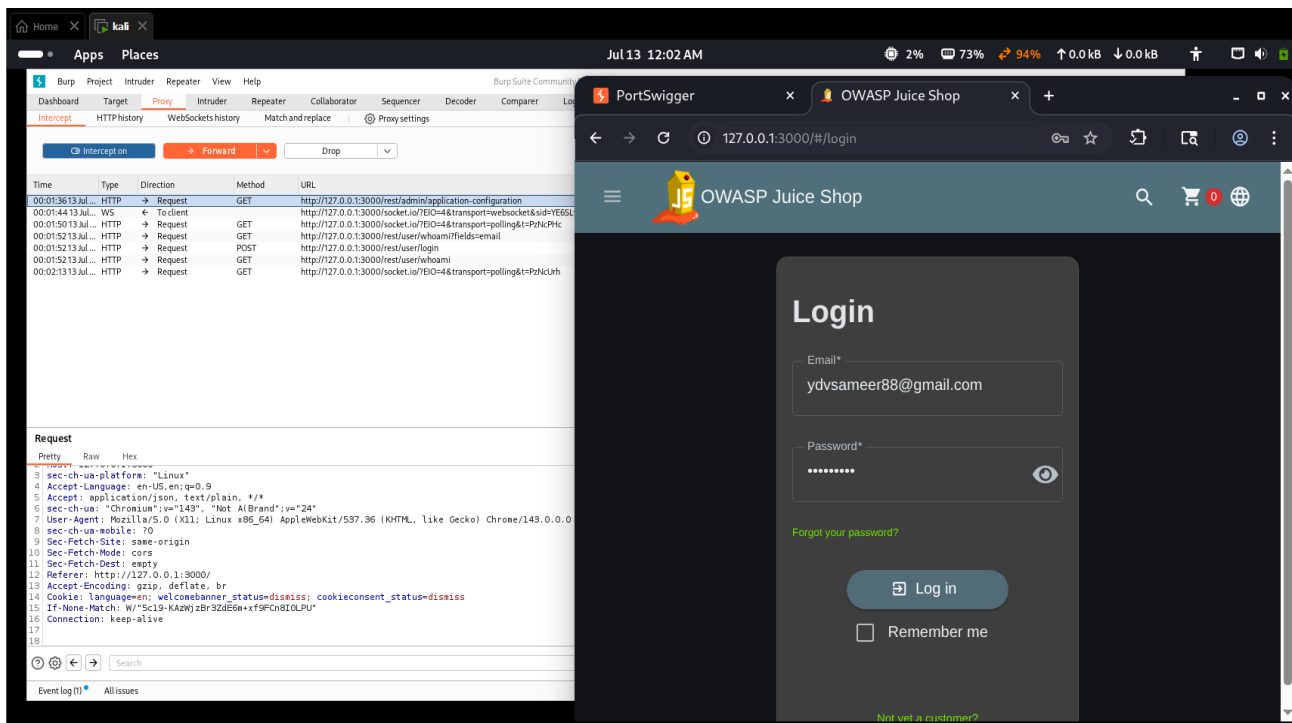
Methodology

Host Discovery → Service Enumeration → Aggressive Scan → Full Port Scan → HTTP Enumeration → Nikto → Burp Validation.

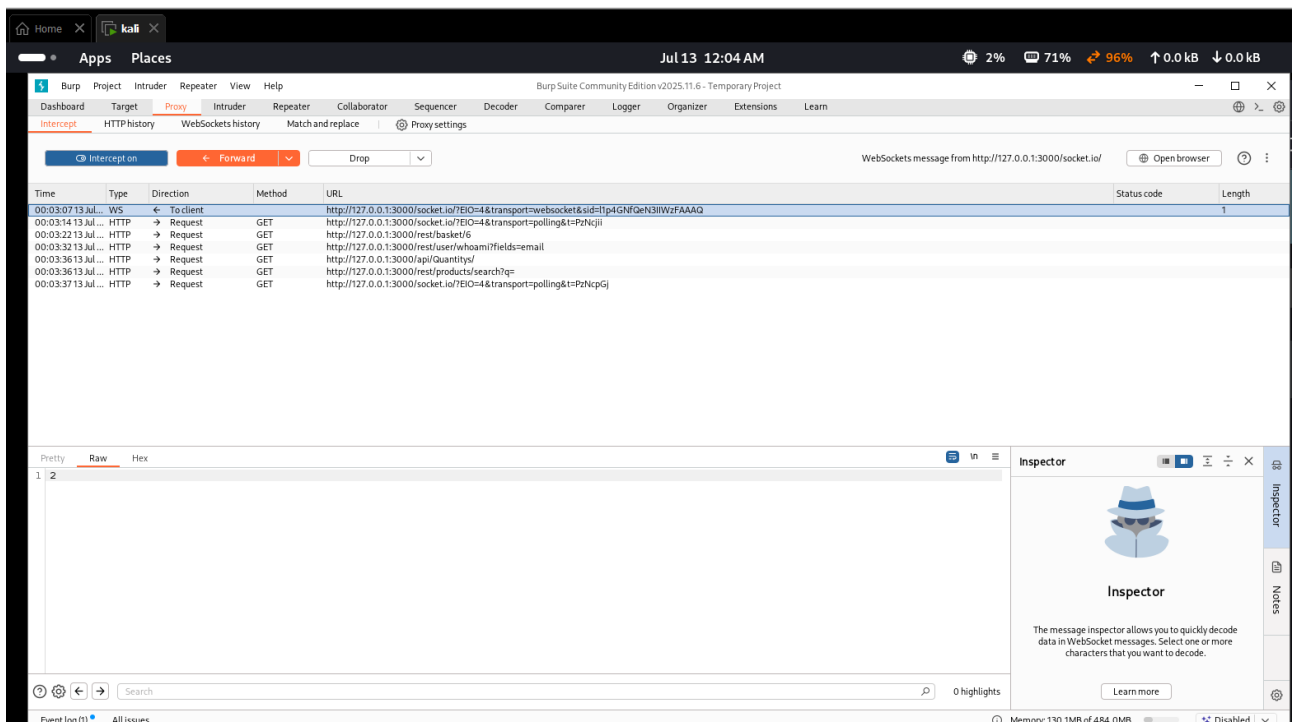
Finding	Severity
Host reachable	Info
Port 3000 exposed	Info
Ephemeral port detected	Info
Missing Content-Security-Policy	High
Missing Permissions-Policy	Medium
Missing Strict-Transport-Security	Medium
Missing Referrer-Policy	Low

Evidence

Screenshot 2026-07-13 000235.png



Screenshot 2026-07-13 000408.png



Screenshot 2026-07-13 000532.png

Home

kali

AppsPlaces

Jul 13 12:05 AM

2%71%99%↑ 0.3 kB↓ 0.2 kB

DashboardTargetProxyIntruderRepeaterViewHelp

InterceptHTTP historyWebSockets historyMatch and replaceProxy settings

Intercept onForwardDrop

WebSockets message to http://127.0.0.1:3000/socket.io/

Open browser

Time	Type	Direction	Method	URL	Status code	Length
00:04:27.13 Jul...	WS	→ To server		http://127.0.0.1:3000/socket.io/?EIO=4&transport=websocket&sid=ink4vQW/qYj2A_SAAAU		44
00:04:27.13 Jul...	HTTP	→ Request	GET	http://127.0.0.1:3000/api/Address		
00:04:36.13 Jul...	HTTP	→ Request	GET	http://127.0.0.1:3000/rest/user/whoami?fields=email		
00:04:36.13 Jul...	HTTP	→ Request	GET	http://127.0.0.1:3000/rest/basket/6		
00:04:37.13 Jul...	WS	← To client		http://127.0.0.1:3000/socket.io/?EIO=4&transport=websocket&sid=ink4vQW/qYj2A_SAAAU		1
00:04:43.13 Jul...	HTTP	→ Request	GET	http://127.0.0.1:3000/socket.io/?EIO=4&transport=polling&t=Pthk3Xj		
00:05:00.13 Jul...	HTTP	→ Request	GET	http://127.0.0.1:3000/api/Address		
00:05:05.13 Jul...	HTTP	→ Request	GET	http://127.0.0.1:3000/socket.io/?EIO=4&transport=polling&t=Pthk8B5		

PrettyRawHex

1: 42["verifyLocalXssChallenge","apple ponace"]

Inspector



Inspector

The message inspector allows you to quickly decode data in WebSocket messages. Select one or more characters that you want to decode.

[Learn more](#)

Event log (1)All issues

Memory: 130.1MB of 484.0MB

Disabled

Recommendations

- Implement Content-Security-Policy
- Configure Permissions-Policy
- Enable HSTS when HTTPS is used
- Add Referrer-Policy
- Periodically review exposed services and perform recurring scans

Conclusion

The assessment successfully validated the OWASP Juice Shop deployment, identified recommended security improvements, and demonstrated practical vulnerability assessment skills in a controlled environment.